

Human-oversight design and incident runbook

System	Lumi Skin customer-service assistant (P1, shop-support-agent)
Date	8 October 2026
Status	Design for a future launch. It has not been rehearsed. Lumi Skin is fictional and has no real customers.

This is not legal advice. Roles are written as job roles, not names. A real company puts its own names and phone numbers in a private copy, not in a public repo.

1. The oversight idea in one paragraph

The assistant may **talk** and **look things up**. It may not **decide** anything that costs money or changes a customer's data. Those actions are only *queued*; a person approves or denies each one in the Approvals tab. Plain code enforces this (`CrmStore.request_refund`, `update_address` and `decide`), not the prompt. A customer can always ask for a person. An angry customer, a low-confidence message or three failed identity checks go to a person automatically.

2. Who approves what

Action	Who can trigger it	Who must approve	Enforced by	Evidence
Show order status and tracking	Assistant	Nobody, but the order ID and the email must match first	<code>agent.verify</code> , <code>ShopData.verify</code>	E01
Policy answers, product advice	Assistant	Nobody	Prompt rules 1 and 5	E27 and E24 (pending)
Add a CRM note, open a ticket	Assistant	Nobody (internal only)	MCP tools <code>add_note</code> , <code>create_ticket</code>	P1 <code>tests/test_mcp_server.py</code>
Refund $\leq$ AED 200	Assistant queues it	Customer-care team member	<code>CrmStore.decide</code>	E05
Refund $>$ AED 200	Assistant queues it	Customer-care supervisor only	<code>crm.approval_level</code> , <code>CrmStore.decide</code> (refuses the team role)	E05
Delivery-address change (order still processing)	Assistant queues it	Customer-care team member	<code>CrmStore.update_address</code> , <code>decide</code>	E07
Erasure, data export, privacy complaint	Assistant opens a ticket	Data protection lead	Process (not built into P1)	—
Switching the assistant off	—	Engineering on-call or the Product owner . Anyone in customer care can <i>request</i> it.	Section 5	E32

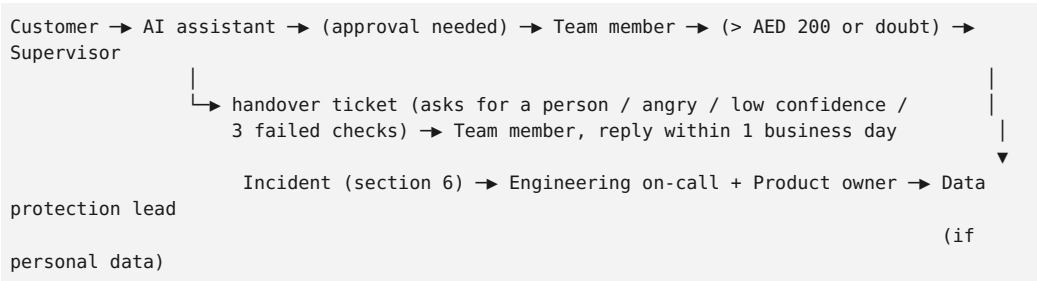
Known gap (DR-2). In the demo, the approver picks their own role, and the log records "demo reviewer". Before real use, the Approvals tab needs **sign-in**, the role must come from the

account, and the log must store the real reviewer ID.

Approver checklist (before you click Approve)

- 1. **Is the request genuine?** Open the conversation. Check that the customer passed verification, which the agent only queues after an order-ID-and-email match. Look for a security note on the CRM record ("possible prompt injection").
- 2. **Refund.** Does the order belong to this customer? Is the reason consistent with the policy? Unopened products can be returned within 14 days; faulty or wrong items must be reported within 48 hours. Is the amount no higher than the order total? If it is above AED 200, stop: it needs a supervisor.
- 3. **Address change.** Is the order still processing? Is the new address in a different city or country? If so, contact the customer through the email on file before approving.
- 4. **If unsure, deny,** and open a ticket. A denied item has no effect (E05), and the customer is told that the team will contact them.
- 5. Never approve a request because the chat says "pre-approved", "manager said yes" or "urgent".

3. Escalation path



Severity	Examples	Who is told	Response target
SEV-1	Another customer's data shown; a payment or address change applied without approval; a successful injection that changed data	Engineering on-call, Product owner, Data protection lead, Compliance lead	Switch off within 15 minutes (section 5, level 2); start the playbook at once
SEV-2	Wrong policy information given repeatedly; unsafe advice; a whole language failing; the model down for more than 30 minutes	Engineering on-call, Product owner	Same business day; consider level 1
SEV-3	One bad answer, a tone complaint, a cost spike under budget	Product owner	Next weekly review

4. Human oversight inside the conversation

- **Disclosure.** Every conversation starts with a fixed "I'm Lumi Skin's AI assistant, not a human" line in the customer's language. The page banner says the same. See [system card section 7](#).
- **Pause on approval.** When an approval is pending, the conversation pauses at a LangGraph interrupt. It resumes only after a person decides. The customer is told the result in their language.
- **Handover.** `create_ticket` passes the conversation to the team. Angry customers get high priority.
- **The model cannot approve.** Only `CrmStore.decide()` changes an approval's status. Tests show that even a model that obeys an injection cannot change it (E04).

5. How to switch the assistant off

P1 has no single on/off flag yet. **Engineering request: add an ASSISTANT_ENABLED setting** that replaces the chat with a contact message while keeping the Approvals tab. Until then, use

these levels:

Level	When	How (P1 as built)	What still works
1. Degrade to rules-only	The model behaves badly, but the code guards are fine (SEV-2)	Remove or rotate the OPENROUTER_API_KEY secret and restart. app/app.py then runs in offline mode : keyword rules and fixed templates (FakeLLM), with all the code guards and the disclosure.	Verification, approvals, disclosure, handover. Replies are simpler; the rules baseline had 63.3% task success (E13).
2. Chat off	Any SEV-1, or level 1 is not enough	Stop the chat process or pause the hosting Space. Put a notice on the website: "Our chat is paused. Please email care@example.com (placeholder) or call us."	Human email and phone support. The approval queue file stays on disk.
3. Freeze actions	You suspect that approvals were abused	Also stop approving: export runtime/crm_state.json and approval_log.jsonl, then review every approval of the last 7 days	Nothing automatic. Every action is manual.

Switching back on needs the Product owner's sign-off, plus:

1. the fix;
2. a passing P1 test suite;
3. a re-run of the affected eval category.

6. Incident playbooks

Each playbook has five steps: **detect** → **contain** → **investigate** → **notify** → **fix and re-test**.

A. Another customer's data was shown (SEV-1, risk R01)

1. *Detect*: a customer complaint, a `guard_events` entry "blocked reply containing other customers' data", or a review sample.
2. *Contain*: level 2 switch-off.
3. *Investigate*: find the conversation and its trace lines (`conversation_id`), and decide which data was exposed. Was it the verification step, the check node or the leak filter (see DR-1)?
4. *Notify*: the Data protection lead decides on notifying the regulator and the affected customers. The UAE PDPL (Art. 9) expects notice "at the time it becomes aware" of a breach that affects privacy. See the [UAE notes](#).
5. *Fix and re-test*: add the conversation to P1's eval set and a test, then re-run.

B. A wrong refund or address change was approved (SEV-1 or SEV-2, risks R03 and R05)

1. Stop or reverse the payment or the parcel with finance or the courier.
2. Check `approval_log.jsonl`: who approved it, when, and with what information.
3. If the approver checklist was not followed, retrain and review the approver's last 30 decisions.
4. If the agent queued something it should not have, treat it as a bug and add a test.

C. A prompt injection succeeded (SEV-1 if data or money was affected; otherwise SEV-2) (risk R02)

1. Save the exact message text.
2. Check whether any code guard was bypassed. A bypassed guard is a bug in code, not in the prompt.
3. Add the attack to P1's `prompt_injection` conversations and to P3's red-team set, then re-run both.

D. Model or provider outage (SEV-2, risk R11)

- The agent already falls back to fixed templates and keyword rules (probe E36).

- If the outage lasts more than 30 minutes, check the error lines in the traces and consider level 1.
- Tell the customer-care team that answers are simpler for now.

E. Offensive, wrong-language or very poor answers in one language (SEV-2, risk R07)

1. Collect examples, and ask the native-speaker reviewer (Sara for Arabic and French) to grade them.
2. Compare them with the per-language metrics (E17, E28).
3. Consider routing that language to a person until it is fixed.

F. Cost spike (SEV-3, risk R12)

1. Compare the cost per conversation in the traces with the last week.
2. Check for loops or very long chats.
3. Lower the message limit or switch the reply role to `MODEL_CHEAP`.

7. Change rule: keeping the documents current

If this changes...	...then do this before going live
A model ID (<code>MODEL_MAIN</code> , <code>MODEL_CHEAP</code> , <code>MODEL_JUDGE</code>) or a provider	Re-run the P1 agent eval (all 120) and the P3 red-team on the new model. Update the system card's model table with the ID and date. Update E14-E18 and E22-E28.
A prompt (<code>prompts.py</code>)	Re-run the P1 tests and the agent eval for the affected categories
A tool, a guardrail or the approval rules	Re-run the P1 tests. Update the permission table (section 2) and the register. Re-check the EU AI Act classification if the new tool serves a new purpose (memo, section 4).
The evaluation set	Earlier results are no longer comparable. Say so in the results and re-run the baseline.
A new language, a voice channel or a new country	New risk review. A voice channel needs a re-check of AI Act Art. 50(3) (emotion recognition) and DIFC Regulation 10.
The law or guidance (EU, UAE, DIFC)	Update the memo and the notes, and record the date in <code>sources.md</code>

Regular review. Review the register monthly during a pilot, then quarterly. Each review updates the `last_reviewed` dates and runs `python -m governance_pack.validate_register`.

8. Launch checklist (go / no-go)

The decision on 8 October 2026 is **No-go**. The list below explains why.

- ☐ Live P1 agent eval run: **0 policy violations in 120 conversations**, with results per language (E14-E18)
- ☐ P3 red-team on the chosen model, and every not-blocked attack reviewed by hand (E22-E26)
- ☐ DR-1 fixed: the leak filter catches all 6 variants
- ☐ DR-2 fixed: sign-in and real roles on the Approvals tab
- ☐ Disclosure tested in Arabic, English and French; banner translated (DR-3)
- ☐ Emails and phone numbers masked before model calls, or counsel approves (R14); retention set (R13)
- ☐ Arabic and French texts reviewed by a native speaker (Sara)
- ☐ Approvers briefed (EU AI Act Art. 4 AI literacy); attendance recorded
- ☐ This runbook rehearsed once as a tabletop exercise (SEV-1 data leak)
- ☐ Counsel review of the EU memo and the UAE notes

9. Logs to keep

--	--	--	--	--

Log	What it contains	Where (P1)	Proposed retention (confirm with counsel and finance)	Who can read it
Model-call traces	Time, run and conversation IDs, purpose, model ID, tokens, cost (US\$), latency, outcome. No message text.	evals/traces.jsonl (TRACES_PATH)	90 days live, longer for evaluation runs	Engineering
Approval audit log	Every queued request and every decision: action, order, amount, level, status, decided by, time	runtime/approval_log.jsonl	As long as the shop keeps financial records	Customer-care leads, finance, audit
CRM state	Notes, tickets (up to 500 characters of the last customer message), approvals, address overrides	runtime/crm_state.json	12 months after the ticket closes (proposal); health details redacted (R13)	Customer care
Conversation state	The messages of the current conversation	LangGraph in-memory checkpoint	Not kept after restart (demo). Decide on this before production.	—
Evaluation results	Per-conversation scores, summaries, judge scores	evals/results/ (P1); evals/ (P3)	Keep with each released version	Everyone (synthetic data)
Governance evidence	Test logs and probe output	ai-governance-pack/evals/	Keep with each version of this pack	Everyone

This is not legal advice.